

Documento de Entrega - Tech Challenge FIAP

Data da entrega: 29/06/2026

Projeto: AutoCare Hub

1. Nome do integrante

Entrega individual - Yasmin Barcelos Pires

2. Participante e username no Discord

Nome completo	RM	Username no Discord	Papel no projeto
Yasmin Barcelos Pires	RM370897	yxsbx	Desenvolvimento individual do projeto

3. Link da documentação

A documentação principal da entrega está versionada no repositório do projeto.

- **README do projeto:**
 - [README.md](#)
- **Levantamento de requisitos:**
 - [docs/REQUIREMENTS.md](#)
- **Arquitetura, HLD, LLD e C4:**
 - [docs/ARCHITECTURE.md](#)
- **Documentação DDD:**
 - [docs/DDD_DOCUMENTATION.md](#)
- **Domain Storytelling:**
 - [docs/DOMAIN_STORYTELLING.md](#)
- **Event Storming:**
 - [docs/EVENT_STORMING.md](#)
- **Contrato OpenAPI:**
 - [docs/openapi/openapi.yaml](#)
- **Estratégia de testes:**
 - [docs/TESTING.md](#)
- **Análise estática e qualidade:**
 - [docs/STATIC_ANALYSIS.md](#)
- **Relatório de vulnerabilidades:**
 - [docs/SECURITY_REPORT.md](#)

4. Link do repositório

Repositório privado: <https://github.com/yxsbx/SOAT-FIAP>

O acesso de leitura ao repositório privado foi concedido ao usuário *soat-architecture*. A branch final de entrega é *main*.

5. Relatório com análise de vulnerabilidades encontradas no sistema

Esta seção consolida a análise de vulnerabilidades da entrega. Os detalhes completos, comandos e evidências estão registrados no arquivo **docs/SECURITY_REPORT.md**.

5.1 Escopo analisado

- Dependências backend Java/Maven analisadas pelo OWASP Dependency-Check.
- Dependências frontend Vue/Vite analisadas por npm audit.
- Imagens Docker de backend e frontend analisadas por Docker Scout.
- Histórico Git analisado por Gitleaks para verificar exposição de secrets.
- Código backend, frontend e Dockerfiles analisados com Semgrep.
- Evidências de cobertura registradas pelo JaCoCo como apoio à qualidade da entrega.
- API local analisada com OWASP ZAP a partir do contrato OpenAPI em */v3/api-docs*.

5.2 Resultado geral dos scans finais

Categoria	Crítica	Alta	Média	Status final
Dependências backend	0	0	0	Corrigido
Dependências frontend	0	0	0	Corrigido
Imagem backend	0	0	1	Risco médio aceito
Imagem frontend	0	0	1	Risco médio aceito
Análise estática	0	0	0	Semgrep sem achados
Secrets	0	0	0	Gitleaks sem leaks
OWASP ZAP API scan	0	0	0	Corrigido

Os scans finais não deixaram vulnerabilidades críticas ou altas abertas. Permanecem duas CVEs médias aceitas como risco residual: uma em *jackson-databind* transitivo na imagem backend, porque a versão corrigida indicada pelo Docker Scout foi verificada com *mvn dependency:get* e ainda não estava disponível no Maven Central na validação, e uma em *BusyBox* na imagem frontend, porque o scanner não indicou versão corrigida disponível.

5.3 Vulnerabilidades encontradas e tratamento

ID	Ferramenta	Severidade	Pacote/área afetada	Status
VULN-001	OWASP Dependency-Check	Alta/Média	log4j-api-2.24.3.jar	Corrigido
VULN-002	OWASP Dependency-Check	Alta	postgresql-42.7.10.jar	Corrigido
VULN-003	OWASP Dependency-Check	Crítica/Alta/Média	spring-boot-3.5.13.jar e starters	Corrigido
VULN-004	OWASP Dependency-Check	Alta/Média/Baixa	spring-core-6.2.17.jar e spring-web-6.2.17.jar	Corrigido
VULN-005	OWASP Dependency-Check	Alta/Média/Baixa	spring-security-core-6.5.9.jar e spring-security-web-6.5.9.jar	Corrigido

VULN-006	OWASP Dependency-Check	Crítica/Alta/Média/Baixa	tomcat-embed-core-10.1.53.jar	Corrigido
VULN-007	OWASP Dependency-Check	Média	commons-compress-1.24.0.jar	Corrigido
VULN-008	OWASP Dependency-Check	Média	commons-lang3-3.17.0.jar	Corrigido
VULN-009	OWASP Dependency-Check	Média/Desconhecida	swagger-ui-5.32.2.jar	Corrigido
VULN-010	npm audit	Alta	vite, esbuild e @vitejs/plugin-vue	Corrigido
VULN-011	npm audit	Média	js-yaml-4.1.1 transitivo do ESLint	Corrigido
VULN-012	Docker Scout	Crítica/Alta/Média	/usr/bin/pebble da imagem runtime anterior	Corrigido
VULN-013	Docker Scout	Crítica/Alta/Média	Imagem frontend Nginx 1.27/Alpine antiga	Corrigido
RISK-001	Docker Scout	Média	BusyBox da imagem frontend atual	Aceito temporariamente
RISK-002	Docker Scout	Média	jackson-databind 2.21.4 transitivo da imagem backend	Aceito temporariamente

5.4 Correções aplicadas

- Atualização de dependências Maven vulneráveis e reexecução do Dependency-Check final sem achados.
- Atualização das dependências frontend vulneráveis, incluindo Vite, plugin Vue, esbuild transitivo e js-yaml.
- Regeneração do package-lock.json após as correções do frontend.
- Atualização direta do Swagger UI.
- Migração da imagem backend para runtime distroless Java 21 non-root.
- Migração da imagem frontend para Nginx unprivileged mainline-alpine-slim, fixada por digest.
- Validação de secrets com Gitleaks, sem leaks encontrados no histórico analisado.
- Análise estática com Semgrep, sem achados no escopo executado.
- Execução de OWASP ZAP API scan contra /v3/api-docs, com 0 falhas e 2 avisos revisados.

5.5 Risco residual aceito

As vulnerabilidades mantidas após os scans finais são duas CVEs médias aceitas temporariamente. A primeira está em jackson-databind 2.21.4, dependência transitiva usada na imagem backend; o Docker Scout indica correção em 2.21.5, mas essa versão ainda não estava disponível no Maven Central na validação. A segunda está no BusyBox da imagem frontend; o Docker Scout informou que não havia versão corrigida disponível na base analisada. Como mitigação, os containers permanecem configurados com usuário não privilegiado, filesystem read-only quando aplicável e sem novos privilégios.